EWB COURSES: Assessment 01 - Security Foundations

Name: Ashish Kumar
College: Jai Narain College of Technology, Bhopal
Internship Name: Ewb AI-Powered Cybersecurity
Batch: October 2026

Task A: *Secure a Student Account*

Scenario: Mira uses the same short password for her email and learning portal. She approves unexpected sign-in prompts, postpones device updates and keeps her only project copy on one laptop. A friend sometimes uses that laptop under Mira's signed-in account.

A1 & A2: Risk Analysis and Controls

Risk	Assets at risk	CIA impact	Practice Control	Limitation
1. Uses the same short password for email and portal	Email and learning portal accounts	**Confidentiality & Integrity:** A short password is easily guessed or cracked. Reusing it means a breach of one platform gives an attacker full access to read private emails and alter academic data on the other.	Use a password manager to generate and store long, unique passwords for every account.	If the master password is forgotten or compromised, the user loses access to or exposes all stored accounts.
2. Approves unexpected sign-in prompts	Account access and session tokens	**Confidentiality & Integrity:** An unexpected MFA prompt may indicate that someone is attempting to sign in using the account's credentials, although the prompt alone does not prove this. Approving a request that Mira did not initiate may authorise that sign-in attempt and expose account information or settings.	Enable number-matching MFA, requiring the user to type a number shown on the login screen into their phone.	Requires the organization's authentication system and the user's authenticator app to support number-matching.

3. Postpones device updates	Laptop (OS and stored files)	**Confidentiality, Integrity, & Availability:** Unpatched software leaves the laptop vulnerable to known malware or ransomware, which can steal, corrupt, or completely encrypt her data.	Turn on automatic updates for the operating system and critical applications.	Updates can occasionally cause software bugs or interrupt active work with forced system reboots.
4. Keeps only project copy on one laptop	Academic project files	**Availability:** If the laptop is lost, stolen, or suffers a hardware failure, the only copy of her project is permanently destroyed.	Set up automatic cloud synchronization (e.g., OneDrive or Google Drive) for all project folders.	Cloud backups require a stable internet connection and consume available storage quota.
5. Friend uses laptop under Mira's signed-in account	Personal session data and local files	**Confidentiality & Integrity:** The friend can intentionally or accidentally read Mira's private emails, access portal files, or send messages under Mira's identity.	Create a separate "Guest" account on the laptop and enforce a screen lock when stepping away.	Relies entirely on human habit; it fails if Mira forgets to lock the screen before handing over the device.

Priority:

1. **Stop approving unexpected MFA prompts and contact college IT.** This is the immediate priority because an unexpected prompt may indicate that someone is attempting to sign in using the account’s credentials. Approving it can authorise an authentication request that the student did not initiate.

2. **Secure the account with a unique password and review active sessions.** Change a reused or potentially exposed password through the genuine college portal. Ask IT to revoke suspicious sessions or tokens, and change the password on any other account where the old password was reused.
3. **Keep the device updated and maintain a recoverable backup.** Install security updates promptly and store project files in a location with version history or another separate backup. This reduces the risk of exploitation and data loss, although updates can occasionally cause compatibility issues and backups must be checked to ensure recovery is possible.

A3: Authentication vs. Authorisation:

- **Authentication** *proves who the user is*. When Mira types her email, enters her password, and approves an MFA prompt on her phone, the learning portal verifies these credentials to confirm her identity.
- **Authorisation** *determines what the user is allowed to do* after their identity is verified. Once authenticated, the portal authorises Mira to view her own courses and submit her assignments, but denies her permission to view other students' grades or alter course structures.

Task B: *Analyse a suspicious message*

B1. Warning Signs Analysis Table

#	Exact Quote	Why it needs scrutiny
1	From: Scholarship Desk <awards@campus-awards.example>	The college officially uses the campus.example domain. The sender is using a deceptive look-alike domain (campus-awards.example) to trick the student into believing it is official communication.
2	Subject: FINAL WARNING - scholarship expires in 20 minutes	This creates a false sense of extreme urgency. Attackers use panic-inducing deadlines to force victims into acting quickly without thinking or verifying the request.
3	"enter your college password and OTP"	Legitimate institutions will never ask a user to type an OTP and password into an unprompted, external verification link. OTPs are strictly for active session authentication. An unsolicited request for a college password and OTP is highly suspicious and should be verified independently.
4	"Do not contact the college office because their system is unavailable."	The attacker is attempting to isolate the victim. By discouraging contact with official support channels, they prevent the student from verifying the scam.
5	"Reply with a photo of your identity card to speed up payment."	This is an explicit attempt at identity theft and data harvesting. Official bodies do not ask for sensitive identity documents via unsecured email replies. Sending an identity-card image by email could expose sensitive information to misuse.

B2, B3, & B4. Verification and Response Plan:

Safe Verification Process (B2):

1) Do not click the link. Open a new browser tab and manually navigate to the known, official campus.example portal from a bookmark to check for legitimate notifications.

2) Contact the source independently. Call the college scholarship office using a verified phone number from the official website, ignoring the email's claim that systems are down.

Note on HTTPS and Display Names: A familiar display name ("Scholarship Desk") can be easily typed and spoofed by anyone. Furthermore, HTTPS only encrypts the traffic between your browser and the website; it does not guarantee the website itself is safe or legitimate (attackers frequently register SSL certificates for fake domains like campus-awards.example).

Incident Response Plan for Compromised Credentials (B3):

1) Immediate Containment: The student must immediately log into the real campus.example portal (if still accessible) and change their password to invalidate the stolen credentials and cut off attacker access.
2) Official Reporting: Report the compromise immediately to the college IT security team or helpdesk using official channels, notifying them that an OTP was also handed over.
3) Follow-up Checks: Review recent account activity (like sign-in logs or sent folder) for unauthorized actions, and monitor for identity fraud if the ID card photo was actually sent.

Missing Evidence (B4):

Missing Fact: From the text alone, we cannot establish the true originating server of the email (whether it was genuinely sent from a server owning campus-awards.example or if the address was entirely spoofed).

Additional Evidence Needed: One important unknown is whether the visible sender address accurately represents the message's sending infrastructure. The address and display name alone cannot conclusively identify the person who sent it. Full email headers, together with SPF, DKIM and DMARC authentication results, could help assess whether the message passed

domain-authentication checks and identify its apparent sending infrastructure. However, these checks would not necessarily establish the identity of the individual sender. The message should therefore be treated as suspicious while its origin remains unconfirmed.

Task C: Triage a sign-in alert

C1. Four-Point Timeline

09:00–09:01 — Successful sign-in and MFA

- **Observation:** At 09:00, student07 had a successful password sign-in from 192.0.2.10. At 09:01, an MFA approval was recorded from the same IP address.
- **Interpretation:** These events are consistent with a successful sign-in. The assessment identifies 192.0.2.10 as the usual classroom egress, but this alone does not establish who used the account.

10:14–10:16 — Failed attempts followed by password success

- **Observation:** Password authentication failed twice from 198.51.100.23, at 10:14 and 10:15, before succeeding at 10:16.
- **Interpretation:** The sequence is suspicious because unsuccessful attempts were followed by a successful password check. It could indicate that someone eventually supplied the correct password, but the logs do not establish how the password was obtained or who entered it.

10:17–10:18 — MFA denied and then approved

- **Observation:** An MFA request was denied at 10:17 and approved at 10:18. The student reports approving a prompt because they thought it would stop repeated requests.
- **Interpretation:** This is consistent with MFA-prompt fatigue or an unexpected authentication request being approved. The student's statement raises concern that the approval may not have represented a sign-in they intended.

10:20 — Session created

- **Observation:** A session was created at 10:20.

- **Interpretation:** This is consistent with authentication completing and a session being established. Given the student's statement, the session should be investigated as potentially unauthorised. The log alone does not identify the person behind the IP address or prove what actions were taken during the session.

C2. Explanations and Additional Checks

Likely explanation: The events at 10:14–10:20 raise concern that someone may have attempted to access the student's account using a correct password and obtained MFA approval. The student's statement that they approved a prompt to stop repeated requests supports the possibility of MFA-prompt fatigue. The session created at 10:20 is consistent with successful authentication, but the evidence does not conclusively identify the person responsible.

Alternative explanations: The events could also reflect a legitimate sign-in from another network, repeated password-entry errors, or an authentication process the student did not recognise. These alternatives do not remove the concern created by the student's statement and the unexpected MFA approval; they show why the logs should be investigated rather than treated as definitive proof of an attacker's identity.

Two useful checks

1. Review available authentication, MFA and session audit records, including device details, session identifiers, timestamps and any available sign-in context, to determine whether the events match the student's known activity.
2. Review activity after 10:20, such as account changes, file access, messages, new security settings or other available audit events, to check whether the session was used for suspicious actions.

   The addresses 192.0.2.10 and 198.51.100.23 are reserved for documentation examples. They should not be used to infer a real person's location, ISP or identity.

C3. Prioritised Response Actions for IT

1. **Contain the possible compromise.** Revoke active sessions and tokens, secure the account, and reset the password through the verified college process. Check whether the password was reused elsewhere and stop further unexpected MFA approvals.
2. **Preserve evidence.** Retain the available sign-in, MFA, session and account audit logs, including timestamps and relevant metadata. Preserve the suspicious email or related records if relevant. Do not delete logs or assume that network-traffic records exist if none have been provided.
3. **Investigate post-login activity.** Review events after 10:20 for unauthorised changes, access to files, messages, security-setting changes or other suspicious activity. Document findings and escalate them through the college's incident-response process.

C4. Incident Summary

The logs show a successful password check at 10:16, an MFA denial at 10:17, an MFA approval at 10:18, and session creation at 10:20 from the documentation IP 198.51.100.23. The student says they did not sign in after 09:05 and approved a prompt to stop repeated requests. This raises concern about possible unauthorised access and MFA-prompt fatigue, but the logs do not identify the person behind the IP or prove what actions followed. IT should secure the account, revoke active sessions, preserve available evidence, and investigate post-login activity.

Task D: Review an AI security answer

D1. Unsafe or Unsupported Claims and Corrections

Claim 1: "The email is safe because it uses HTTPS."
Correction: HTTPS only encrypts the traffic between the browser and the web server; it does not guarantee the website itself is benign. Malicious actors frequently register SSL certificates to make their phishing domains appear legitimate.

Claim 2: "The sign-in logs prove that the person using 198.51.100.23 stole the password."
Correction: An IP address alone cannot identify a specific person or prove who entered the password. In this assessment, 198.51.100.23 is a reserved documentation example, so it cannot be used to attribute a real-world person or location. The logs establish a sequence of authentication events, not the identity of the person responsible.

Claim 3: "MFA prevents every account compromise."
Correction: MFA is highly effective but not foolproof. It can be bypassed through social engineering techniques like MFA fatigue (prompt bombing) or technically through adversary-in-the-middle (AiTM) session hijacking.

Claim 4: "Delete the suspicious logs."
Correction: System logs are critical forensic evidence during a security incident. Deleting them destroys the ability to investigate the scope of the breach and identify what the attacker accessed.
Claim 5: "Send the student's password to support so they can test it."

Correction: Passwords must never be shared with anyone, including IT support personnel. Support teams should rely on secure password resets and session revocations, never requesting plaintext secrets.

D2. Optimized AI Prompt

Prompt: Act as a cybersecurity analyst reviewing only the fictional email evidence and synthetic sign-in logs supplied in this assessment. Identify warning signs, construct a timeline, and recommend proportionate response actions. Clearly distinguish observed facts from interpretations and assumptions. Explain what the evidence cannot establish, including the identity behind an IP address. Do not visit the sample links, request or reproduce passwords or OTPs, use real personal data, or recommend deleting evidence. Verify security claims against the assessment's supplied references and state any remaining uncertainty.

D3. Corrected Security Advice:

The scholarship email should be treated as suspicious because it creates urgency, requests a college password and OTP, discourages independent contact, and asks for identity information. HTTPS does not prove that a website is legitimate, and a sender display name can be misleading. Verify the scholarship through the official college portal or a contact method obtained independently. The sign-in logs show password failures followed by success, an MFA denial and approval, and a session creation. Together with the student's statement, these events raise concern about possible unauthorised access and MFA-prompt fatigue. However, the logs do not establish the identity of the person behind the IP address or prove what happened after session creation. IT should revoke active sessions, secure the account, preserve available evidence, and investigate subsequent activity. Passwords and OTPs must never be sent to support.

D4. AI-Use Declaration and References

AI-use declaration: I used AI to review my cybersecurity assessment, identify areas requiring clarification, and suggest improvements to wording and technical explanations. I reviewed the suggestions and am responsible for checking the accuracy of the final submission and ensuring that it follows the assessment requirements and my institution's rules on AI assistance.

Evidence and reference notes:

1. **CISA — Secure Our World:** https://www.cisa.gov/secure-our-world
   This resource supports general cybersecurity practices such as using strong, unique passwords, enabling multifactor authentication, recognising phishing, and installing software updates.
2. **NIST — Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1):** https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf
   This resource provides context for considering generative-AI risks and evaluating AI outputs critically. AI-generated security advice should be checked against the available evidence and appropriate authoritative references rather than accepted automatically.